

0.1 Kết luận

Đồ án tốt nghiệp này đặt ra mục tiêu xây dựng một hệ thống quản lý định danh và phân quyền (IAM) nội bộ, phục vụ nhu cầu kiểm soát quyền truy cập cho các lập trình viên và cán bộ ngân hàng trong môi trường đa ứng dụng. Xuất phát từ bài toán thực tế là các hệ thống IAM thương mại như Keycloak hay Microsoft Azure AD, dù mạnh mẽ và đầy đủ tính năng, chưa đáp ứng được đặc thù quản lý vòng đời nhân sự và quy trình phê duyệt nội bộ của ngân hàng, đồ án đã đề xuất và hiện thực hóa một giải pháp tích hợp, bám sát đặc thù nghiệp vụ từ giai đoạn tiếp nhận nhân sự đến khi chấm dứt hợp đồng.

Về những gì đã đạt được, đồ án đã xây dựng và triển khai thành công hệ thống IAM gồm năm dịch vụ microservices độc lập: *iam-auth-service* chịu trách nhiệm xác thực OAuth2/OIDC và phát hành token; *iam-identity-service* quản lý vòng đời người dùng và quyền hạn; *iam-app-service* quản lý cấu hình ứng dụng và luồng xác thực; *iam-gateway* thực thi kiểm tra quyền tại mọi điểm vào của hệ thống; và *iam-notify-service* gửi thông báo qua email theo các sự kiện nghiệp vụ. Toàn bộ hệ thống được hỗ trợ bởi một ứng dụng minh họa là *demo-change-app* — mô phỏng quy trình Change & Go-Live Management — nhằm kiểm chứng tính năng phân quyền trong bối cảnh thực tế.

Các đóng góp kỹ thuật nổi bật của đồ án tập trung vào ba điểm khác biệt so với các giải pháp thương mại hiện có. Thứ nhất, mô hình RBAC được mở rộng với chiều vị trí công tác ($\text{Role} \times \text{Position}$), cho phép ma trận quyền mặc định tự động cấp phát ngay khi nhân sự được tiếp nhận, luân chuyển hoặc thăng chức mà không cần can thiệp thủ công. Thứ hai, vòng đời quyền được tự động hóa hoàn toàn thông qua sự kiện Kafka: quá trình tiếp nhận tự động cấp quyền mặc định, quá trình thôi việc và luân chuyển tự động thu hồi quyền từ ứng dụng cũ, trong khi quy trình CAB (Change Advisory Board) đảm bảo mọi yêu cầu phân quyền đặc biệt đều có luồng phê duyệt và nhật ký kiểm toán rõ ràng. Thứ ba, cơ chế thu hồi quyền tức thì qua Kafka đảm bảo phiên làm việc bị vô hiệu hóa trong vài giây sau khi quyền được thu hồi, thay vì phải chờ đến khi JWT hết hạn như trong các hệ thống stateless thông thường.

So sánh với các giải pháp phổ biến như Keycloak hay Azure AD, hệ thống xây dựng trong đồ án có ưu thế rõ rệt ở tính gắn kết nghiệp vụ: vòng đời quyền được liên kết trực tiếp với vòng đời nhân sự, quy trình phê duyệt CAB là một thành phần tích hợp chứ không phải được bổ sung bên ngoài, và chi phí vận hành thấp do hoàn toàn dựa trên các công nghệ mã nguồn mở. Tuy nhiên, đồ án cũng nhận thức rõ một số hạn chế so với sản phẩm thương mại: hệ thống hiện tại chưa hỗ trợ đa đơn vị

(multi-tenant), giao diện trang đăng nhập còn đơn giản so với các sản phẩm thương mại, và hệ thống chưa trải qua kiểm tra hiệu năng trong điều kiện tải thực tế.

Về những điểm chưa hoàn thiện, đề án ghi nhận rằng việc triển khai thực tế mới dừng lại ở mức cụm Docker Compose cục bộ, chưa thể phản ánh đầy đủ yêu cầu về tính sẵn sàng cao và khả năng phục hồi trong môi trường sản xuất. Bên cạnh đó, một số tính năng nâng cao như xác thực không mật khẩu (WebAuthn/FIDO2) hay kiểm soát quyền dựa trên thuộc tính ngữ cảnh (ABAC) chưa được tích hợp, mở ra dư địa đáng kể cho các nghiên cứu và phát triển tiếp theo.

0.2 Hướng phát triển

Trên nền tảng đã xây dựng, đề án xác định hai nhóm hướng phát triển chính: hoàn thiện hệ thống hiện tại và mở rộng tính năng mới.

Trong lĩnh vực hoàn thiện kỹ thuật, ưu tiên trước mắt là triển khai kiểm thử hiệu năng nhằm đánh giá khả năng xử lý thực tế của API Gateway khi đồng thời thực hiện xác minh JWT và kiểm tra quyền hạn dưới tải cao. Song song đó, cần chuyển từ mô hình triển khai Docker Compose cục bộ sang kiến trúc có tính sẵn sàng cao với nhiều instance mỗi dịch vụ, Kafka replication factor tối thiểu bằng hai, và Redis Sentinel hoặc Redis Cluster để loại bỏ điểm hỏng đơn. Hệ thống giám sát tập trung bằng Prometheus và Grafana cũng cần được tích hợp để đội vận hành theo dõi độ trễ, tỷ lệ lỗi và tình trạng các Kafka consumer theo thời gian thực, đáp ứng tiêu chuẩn vận hành của môi trường ngân hàng.

Về mở rộng tính năng, hướng phát triển đầu tiên là hoàn thiện và tích hợp cổng LDAP vào hệ thống chính thức. Hiện tại, đề án đã nghiên cứu và xây dựng thử nghiệm một cổng LDAP với cơ chế mã hóa ứng dụng trong tên phân biệt (distinguished name) theo dạng *uid={username},ou={appServiceCode},ou=users,dc=iam,dc=bank,dc=vn*, cho phép một instance duy nhất phục vụ nhiều ứng dụng khác nhau thông qua việc phân biệt base DN. Khi được tích hợp chính thức, các ứng dụng hãng thứ ba vốn chỉ hỗ trợ xác thực qua LDAP — chẳng hạn GitLab, Kibana hay một số hệ thống quản lý nội bộ — sẽ có thể sử dụng trực tiếp thông tin xác thực và quyền hạn từ IAM mà không cần chỉnh sửa mã nguồn, từ đó mở rộng đáng kể phạm vi phủ của nền tảng trong hệ sinh thái công cụ phát triển phần mềm ngân hàng.

Hướng phát triển thứ hai liên quan đến engine xác thực đa yếu tố. Đề án đã tự xây dựng một MFA engine dạng cây linh hoạt, tuy nhiên trong thực tế triển khai quy mô lớn, cần cân nhắc hai phương án: hoặc tiếp tục mở rộng engine hiện có bằng cách bổ sung thêm các phương thức xác thực mới như OTP qua ứng dụng di động (TOTP/HOTP) và push notification; hoặc tích hợp Keycloak — giải pháp IAM mã nguồn mở trưởng thành — làm lớp xác thực thay thế, trong khi vẫn giữ

nguyên các thành phần quản lý vòng đời quyền và CAB workflow đã xây dựng. Phương án sau giúp hệ thống thừa hưởng hệ sinh thái plugin phong phú và cộng đồng hỗ trợ lâu dài của Keycloak, giảm gánh nặng bảo trì engine tự phát triển.

Hướng phát triển thứ ba và cấp thiết nhất đối với môi trường sản xuất là hoàn thiện pipeline CI/CD và kiến trúc triển khai. Trước hết, cần xây dựng pipeline tự động hóa quá trình build, kiểm thử và đóng gói Docker image cho toàn bộ các service khi có thay đổi mã nguồn. Tiếp đến, để đạt tính sẵn sàng cao, mỗi service cần được triển khai với nhiều replica, cụm Kafka cần cấu hình replication factor tối thiểu bằng hai và có cơ chế leader election tự động, trong khi Redis cần chuyển sang Redis Cluster hoặc Redis Sentinel để loại bỏ điểm hỏng đơn. Kết hợp với hệ thống giám sát tập trung bằng Prometheus và Grafana, kiến trúc này sẽ đáp ứng các tiêu chuẩn vận hành nghiêm ngặt của môi trường ngân hàng và tạo nền tảng để hệ thống IAM phục vụ hàng nghìn người dùng đồng thời một cách ổn định.